

Ticketing PKI Certificate Policy

Abstract

This document describes the certificate policy for a Public Key Infrastructure (PKI) used to support the issuance and validation of barcodes for transport ticketing. Each organisation that issues such tickets will obtain a certificate under this TPki for providing a digital signature over their tickets. These certificates will allow other transport undertakings to verify the authenticity of the ticket barcodes and the issuer's authorisation to issue such tickets.

The RFC Editor will remove this note

This note is to be removed before publishing as an RFC.

The OIDs assigned in this document under 1.3.6.1.4.1.56292.1.3 are not final, and are merely assigned for experimentation purposes.

Table of Contents

1. Introduction	11
1.1. Overview	11
1.2. Document name and identification	11
1.3. PKI participants	12
1.3.1. Certification authorities	12
1.3.2. Registration authorities	12
1.3.3. Subscribers	12
1.3.4. Relying parties	12
1.3.5. Other participants	12
1.4. Certificate usage	12
1.4.1. Appropriate certificate uses	12
1.4.2. Prohibited certificate uses	12
1.5. Policy administration	13
1.5.1. Organization administering the document	13

1.5.2. Contact person	13
1.5.3. Person determining CPS suitability for the policy	13
1.5.4. CPS approval procedures	13
1.6. Definitions and acronyms	13
2. Publication and Repository Responsibilities	13
2.1. Repositories	13
2.2. Publication of certification information	14
2.3. Time or frequency of publication	14
2.4. Access controls on repositories	14
3. Identification and Authentication	14
3.1. Naming	14
3.1.1. Types of names	14
3.1.2. Need for names to be meaningful	15
3.1.3. Anonymity or pseudonymity of subscribers	15
3.1.4. Rules for interpreting various name forms	15
3.1.5. Uniqueness of names	15
3.1.6. Recognition, authentication, and role of trademarks	15
3.2. Initial identity validation	15
3.2.1. Method to prove possession of private key	15
3.2.2. Authentication of organization identity	16
3.2.3. Authentication of individual identity	16
3.2.4. Non-verified subscriber information	16
3.2.5. Validation of authority	16
3.2.6. Criteria for interoperation	16
3.3. Identification and authentication for re-key requests	16
3.3.1. Identification and authentication for routine re-key	16
3.3.2. Identification and authentication for re-key after revocation	16
3.4. Identification and authentication for revocation request	16

4. Certificate Life-Cycle Operational Requirements	16
4.1. Certificate Application	16
4.1.1. Who can submit a certificate application	16
4.1.2. Enrollment process and responsibilities	17
4.2. Certificate application processing	17
4.2.1. Performing identification and authentication functions	17
4.2.2. Approval or rejection of certificate applications	17
4.2.3. Time to process certificate applications	17
4.3. Certificate issuance	17
4.3.1. CA actions during certificate issuance	17
4.3.2. Notification to subscriber by the CA of issuance of certificate	17
4.4. Certificate acceptance	17
4.4.1. Conduct constituting certificate acceptance	17
4.4.2. Publication of the certificate by the CA	17
4.4.3. Notification of certificate issuance by the CA to other entities	17
4.5. Key pair and certificate usage	18
4.5.1. Subscriber private key and certificate usage	18
4.5.2. Relying party public key and certificate usage	18
4.6. Certificate renewal	18
4.6.1. Circumstance for certificate renewal	18
4.6.2. Who may request renewal	18
4.6.3. Processing certificate renewal requests	18
4.6.4. Notification of new certificate issuance to subscriber	19
4.6.5. Conduct constituting acceptance of a renewal certificate	19
4.6.6. Publication of the renewal certificate by the CA	19
4.6.7. Notification of certificate issuance by the CA to other entities	19
4.7. Certificate re-key	19
4.7.1. Circumstance for certificate re-key	19
4.7.2. Who may request certification of a new public key	19
4.7.3. Processing certificate re-keying requests	19

4.7.4. Notification of new certificate issuance to subscriber	19
4.7.5. Conduct constituting acceptance of a re-keyed certificate	19
4.7.6. Publication of the re-keyed certificate by the CA	19
4.7.7. Notification of certificate issuance by the CA to other entities	19
4.8. Certificate modification	19
4.8.1. Circumstance for certificate modification	19
4.8.2. Who may request certificate modification	19
4.8.3. Processing certificate modification requests	20
4.8.4. Notification of new certificate issuance to subscriber	20
4.8.5. Conduct constituting acceptance of modified certificate	20
4.8.6. Publication of the modified certificate by the CA	20
4.8.7. Notification of certificate issuance by the CA to other entities	20
4.9. Certificate revocation and suspension	21
4.9.1. Circumstances for revocation	21
4.9.2. Who can request revocation	21
4.9.3. Procedure for revocation request	21
4.9.4. Revocation request grace period	21
4.9.5. Time within which CA must process the revocation request	21
4.9.6. Revocation checking requirement for relying parties	21
4.9.7. CRL issuance frequency	21
4.9.8. Maximum latency for CRLs	21
4.9.9. On-line revocation/status checking availability	21
4.9.10. On-line revocation checking requirements	21
4.9.11. Other forms of revocation advertisements available	21
4.9.12. Special requirements re key compromise	21
4.9.13. Circumstances for suspension	21
4.9.14. Who can request suspension	21
4.9.15. Procedure for suspension request	21
4.9.16. Limits on suspension period	21

4.10. Certificate status services	21
4.10.1. Operational characteristics	21
4.10.2. Service availability	21
4.10.3. Optional features	21
4.11. End of subscription	21
4.12. Key escrow and recovery	22
4.12.1. Key escrow and recovery policy and practices	22
4.12.2. Session key encapsulation and recovery policy and practices	22
5. Facility, management, and operational controls	23
5.1. Physical controls	23
5.1.1. Site location and construction	23
5.1.2. Physical access	23
5.1.3. Power and air conditioning	23
5.1.4. Water exposures	23
5.1.5. Fire prevention and protection	23
5.1.6. Media storage	23
5.1.7. Waste disposal	23
5.1.8. Off-site backup	23
5.2. Procedural controls	23
5.2.1. Trusted roles	23
5.2.2. Number of persons required per task	23
5.2.3. Identification and authentication for each role	23
5.2.4. Roles requiring separation of duties	23
5.3. Personnel controls	23
5.3.1. Qualifications, experience, and clearance requirements	23
5.3.2. Background check procedures	23
5.3.3. Training requirements	23
5.3.4. Retraining frequency and requirements	23
5.3.5. Job rotation frequency and sequence	23
5.3.6. Sanctions for unauthorized actions	23

5.3.7. Independent contractor requirements	23
5.3.8. Documentation supplied to personnel-	23
5.4. Audit logging procedures	24
5.4.1. Types of events recorded	24
5.4.2. Frequency of processing log	24
5.4.3. Retention period for audit log	24
5.4.4. Protection of audit log	24
5.4.5. Audit log backup procedures	24
5.4.6. Audit collection system (internal vs. external)	24
5.4.7. Notification to event-causing subject	24
5.4.8. Vulnerability assessments	24
5.5. Records archival	24
5.5.1. Types of records archived	24
5.5.2. Retention period for archive	24
5.5.3. Protection of archive	24
5.5.4. Archive backup procedures	24
5.5.5. Requirements for time-stamping of records	24
5.5.6. Archive collection system (internal or external)	24
5.5.7. Procedures to obtain and verify archive information	24
5.6. Key changeover	24
5.7. Compromise and disaster recovery	24
5.7.1. Incident and compromise handling procedures	24
5.7.2. Computing resources, software, and/or data are corrupted	24
5.7.3. Entity private key compromise procedures	24
5.7.4. Business continuity capabilities after a disaster	24
5.8. CA or RA termination	24
6. Technical Security Controls	25
6.1. Key pair generation and installation	25
6.1.1. Key pair generation	25
6.1.2. Private key delivery to subscriber	25

6.1.3. Public key delivery to certificate issuer	25
6.1.4. CA public key delivery to relying parties	25
6.1.5. Key sizes	25
6.1.6. Public key parameters generation and quality checking	25
6.1.7. Key usage purposes (as per X.509 v3 key usage field)	25
6.2. Private Key Protection and Cryptographic Module Engineering Controls	25
6.2.1. Cryptographic module standards and controls	25
6.2.2. Private key (n out of m) multi-person control	25
6.2.3. Private key escrow	25
6.2.4. Private key backup	25
6.2.5. Private key archival	25
6.2.6. Private key transfer into or from a cryptographic module	25
6.2.7. Private key storage on cryptographic module	25
6.2.8. Method of activating private key	25
6.2.9. Method of deactivating private key	25
6.2.10. Method of destroying private key	25
6.2.11. Cryptographic Module Rating	25
6.3. Other aspects of key pair management	25
6.3.1. Public key archival	25
6.3.2. Certificate operational periods and key pair usage periods	25
6.4. Activation data	25
6.4.1. Activation data generation and installation	25
6.4.2. Activation data protection	25
6.4.3. Other aspects of activation data	25
6.5. Computer security controls	26
6.5.1. Specific computer security technical requirements	26
6.5.2. Computer security rating	26
6.6. Life cycle technical controls	26
6.6.1. System development controls	26
6.6.2. Security management controls	26

6.6.3. Life cycle security controls	26
6.7. Network security controls	26
6.8. Time-stamping	26
7. Certificate, CRL, and OCSP Profiles	26
7.1. Certificate profile	26
7.1.1. Version number(s)	26
7.1.2. Certificate extensions	26
7.1.3. Algorithm object identifiers	27
7.1.4. Name forms	27
7.1.5. Name constraints	27
7.1.6. Certificate policy object identifier	27
7.1.7. Usage of Policy Constraints extension	27
7.1.8. Policy qualifiers syntax and semantics	28
7.1.9. Processing semantics for the critical Certificate Policies extension	28
7.2. CRL Profile	28
7.2.1. Version number(s)	28
7.2.2. CRL and CRL entry extensions	28
7.3. OCSP Profile	28
7.3.1. Version number(s)	28
7.3.2. OCSP extensions	28
8. Compliance, Audit, and Other Assessments	29
8.1. Frequency or circumstances of assessment	29
8.2. Identity/qualifications of assessor	29
8.3. Assessor's relationship to assessed entity	29
8.4. Topics covered by assessment	29
8.5. Actions taken as a result of deficiency	29
8.6. Communication of result	29
9. Other Business and Legal Matters	29
9.1. Fees	29
9.1.1. Certificate issuance or renewal fees	29

9.1.2. Certificate access fees	29
9.1.3. Revocation or status information access fees	29
9.1.4. Fees for other services	29
9.1.5. Refund policy	29
9.2. Financial responsibility	29
9.2.1. Insurance coverage	29
9.2.2. Other assets	29
9.2.3. Insurance or warranty coverage for end-entities	30
9.3. Confidentiality of business information	30
9.3.1. Scope of confidential information	30
9.3.2. Information not within the scope of confidential information	30
9.3.3. Responsibility to protect confidential information	30
9.4. Privacy of personal information	30
9.4.1. Privacy plan	30
9.4.2. Information treated as private	30
9.4.3. Information not deemed private	30
9.4.4. Responsibility to protect private information	30
9.4.5. Notice and consent to use private information	31
9.4.6. Disclosure pursuant to judicial or administrative process	31
9.4.7. Other information disclosure circumstances	31
9.5. Intellectual property rights	31
9.6. Representations and warranties	31
9.6.1. CA representations and warranties	31
9.6.2. RA representations and warranties	31
9.6.3. Subscriber representations and warranties	31
9.6.4. Relying party representations and warranties	31
9.6.5. Representations and warranties of other participants	31
9.7. Disclaimers of warranties	31
9.8. Limitations of liability	31
9.9. Indemnities	31

9.10. Term and termination	31
9.10.1. Term	31
9.10.2. Termination	32
9.10.3. Effect of termination and survival	32
9.11. Individual notices and communications with participants	32
9.12. Amendments	32
9.12.1. Procedure for amendment	32
9.12.2. Notification mechanism and period	32
9.12.3. Circumstances under which OID must be changed	32
9.13. Dispute resolution provisions	32
9.14. Governing law	32
9.15. Compliance with applicable law	32
9.16. Miscellaneous provisions	33
9.16.1. Entire agreement	33
9.16.2. Assignment	33
9.16.3. Severability	33
9.16.4. Enforcement (attorneys' fees and waiver of rights)	33
9.16.5. Force Majeure	33
9.17. Other provisions	33
10. References	33
10.1. Normative References	33
10.2. Informative References	34
Appendix A. ASN.1 Definitions	34
A.1. Name Attributes	34
A.1.1. Company Code Name Attribute	35
A.1.2. Key ID Attribute	35
A.2. Extended Key Usages	35
A.2.1. Trust Anchor EKU	35
A.3. Certificate Extensions	36
A.3.1. Revocation Notice Extension	36

Appendix B. STAR Certificate Format	36
Author's Address	36

1. Introduction

This document describes the certificate policy for a Public Key Infrastructure (PKI) used to support the issuance and validation of barcodes for transport ticketing - a Ticketing PKI (TPKI). This PKI is designed exclusively for use in support of validation of claims relating to transport ticketing via barcoded tickets. Use of the certificates, Certificate Revocation Lists (CRLs), or any other artifact managed under this PKI for any other purpose is a violation of this CP, and relying parties (RPs) **MUST** reject certificates presented for such uses.

This document is based on the template specified in[RFC3647], a product of the Internet Engineering Task Force (IETF) stream. Its section numbering has been maintained to allow direct comparison of Certificate Policies and Certification Practice Statements. Certification Practice Statements issued under this PKI **MUST** retain the same section numbering.

The key words **MUST**, **MUST NOT**, **REQUIRED**, **SHALL**, **SHALL NOT**, **SHOULD**, **SHOULD NOT**, **RECOMMENDED**, **NOT RECOMMENDED**, **MAY**, and **OPTIONAL** in this document are to be interpreted as described in [BCP14] when, and only when, they appear in all capitals, as shown here.

1.1. Overview

This document defines a set of technologies, rules, and requirements necessary - but not sufficient - for the operation of a PKI for Ticketing (TPKI). Certificates issued in this PKI are trusted by virtue of their corresponding root CA being installed on the ticket control device concerned.

It is envisaged that there may be several roots in a global TPKI ecosystem. Each of these root CAs will exist to serve a different market. The primary of these will be the UIC's root.

This CP sets a common set of rules that all root CAs must follow, regardless of their specifics of operation, to ensure adequate interoperability between root CAs. Each root CA, and each subordinate CA thereof, **MUST** create and publish a CPS, in compliance with this CP.

These requirements are applicable to all participants in a TPKI.

In the event of a disagreement between this document and other agreements in the TPKI, this document has precedence.

1.2. Document name and identification

This certificate policy (CP) contains the requirements for the issuance and management of certificates for public transport ticketing, as adopted by the UIC's Ticketing Security Working Group (TSG). This document may be cited as TPKI CP vX.X.

This policy has been assigned the following OID:

```
id-uic-tpki-cp-0 OBJECT IDENTIFIER ::= { iso(1) identified-organization(3)
dod(6) internet(1) private(4) enterprise(1) as207960(56292) pki(1) uic(3)
cp(4) 0 }
```

1.3. PKI participants

1.3.1. Certification authorities

The CA is this PKI is responsible for the issuance of certificates in accordance with this CP and its CPS. The primary CA is the root CA. Other participants may be CA insofar as they issue STAR certificates.

1.3.2. Registration authorities

The registration authority is responsible for verifying that applications for new certificate issuance are legitimate and in accordance with this CP and its CPS. The RA checks the subscriber's authority to hold such a certificate, and that this is a genuine request of the subscriber.

It is envisaged that the CA and the RA roles are primarily performed by the same entity, but this CP does not preclude the separation of these functions.

1.3.3. Subscribers

Subscribers are those entities that receive a certificate under this TPKI for signing ticket barcodes. These could be a transport undertaking directly issuing their own tickets, or an organisation authorised to distribute tickets but not operating transport services themselves.

1.3.4. Relying parties

Relying parties are those entities that use certificates from this TPKI to verify the authenticity of tickets barcodes. These are primarily transport undertakings verifying tickets on-board their services.

A relying party may also be a subscriber if they issue tickets as well as verify them.

1.3.5. Other participants

All CAs in the TPKI are responsible for publishing certain artefacts. These duties **MAY** be performed by the CA directly, or **MAY** be outsourced.

1.4. Certificate usage

1.4.1. Appropriate certificate uses

Certificates issued under this CP **MAY** be used for the purposes of verifying ticket barcodes.

1.4.2. Prohibited certificate uses

Certificates issued under this CP **MUST NOT** be accepted for any use outside that of verifying tickets for transport purposes.

1.5. Policy administration

1.5.1. Organization administering the document

This CP is administered by:

International Union of Railways
16 rue Jean Rey
75015 Paris
uic.org

1.5.2. Contact person

TODO

1.5.3. Person determining CPS suitability for the policy

No stipulation. Each root CA in this TPKI is to be judged on its own merits by those trusting it for ticketing purposes.

1.5.4. CPS approval procedures

No stipulation. Each root CA in this TPKI is to be judged on its own merits by those trusting it for ticketing purposes.

1.6. Definitions and acronyms

CPS Certification Practice Statement. A CPS is a document that specifies the practices that a Certification Authority (CA) employs in issuing certificates in this PKI.

STAR Certificate A Short-Term Automatically Renewed certificate, issued in the UIC message recovery signature end-entity certificate format (see [Appendix B](#)), for direct inclusion into a ticket barcode.

UIC The International Union of Railways

RICS Railway Interchange Coding System

ERA European Union Agency for Railways

2. Publication and Repository Responsibilities

2.1. Repositories

Certificates and CRLs **MUST** be made available for downloading by all relying parties. Each CA **MUST** maintain an online, publicly accessible, repository of all certificates and CRLs issued.

Certificates and CRLs **MUST** be provided over HTTP with TLS[[RFC9110](#)]. The certificate repository **MUST** be a DER encoded "certs-only" CMS message as specified in[[RFC2797](#)].

A CA **MAY** publish certificates and CRLs via other means, in addition.

2.2. Publication of certification information

Each CA **MUST** publish the certificates, except STAR certificates, that it issues.

Each CA **MUST** publish the CRLs that it issues.

Each CA **MUST** create and publish a CPS that meets the requirements set forth in this CP. Publication means that the CPS is openly available to the public. It is **RECOMMENDED** that this be via publication on a website.

An organisation **MAY** choose to outsource the publication of data.

2.3. Time or frequency of publication

The CPS for each CA **MUST** specify the following information:

1. The period of time within which a certificate will be published after the CA issues the certificate.
2. The period of time within which a CA will publish a CRL with an entry for a revoked certificate after it revokes that certificate.

The CA **MUST** maintain version control on its CPS, allow retrieval of older versions of its CPS, and indicate when and how its CPS was updated via changelog.

2.4. Access controls on repositories

Participants **MUST** make their repositories publicly available in a read-only manner.

3. Identification and Authentication

3.1. Naming

3.1.1. Types of names

3.1.1.1. Standard certificates

Subjects of certificates are identified via an X.500 Distinguished Name. A name **MUST** contain:

- ISO 3166 [[ISO3166-1](#)] Country Code (2.5.4.6) - country in which the subject is incorporated.
- Organisation name (2.5.4.10) - full legal name of the subject.
- Company code (1.3.6.1.4.1.56292.1.3.2.1, see [Appendix A.1.1](#)) - the UIC RICS of the subject or, if no RICS is available, an otherwise specified company code as per the CA's CPS.

A name **MAY** also contain:

- State or province name (2.5.4.8) - first level administrative subdivision in which the subject is incorporated, per ISO 3166 part 2 [[ISO3166-2](#)].

In the case of an end-entity certificate (i.e. one used to sign tickets) the following attributes **MUST** be present:

- Key ID (1.3.6.1.4.1.56292.1.3.2.2, see [Appendix A.1.2](#)) - a unique identifier for a subject's key pair, to allow for correlating public keys and signatures in tickets.

In the case of non end-entity certificates, the following attributes **MUST** be present:

- Common Name (2.5.4.3) - a textual description of the purpose of this certificate, e.g. "UIC Root CA" or "UIC Intermediate CA 1"

A CA may, in its CPS, define the inclusion of other attributes.

3.1.1.2. STAR Certificates

A STAR certificate, per specification, contains a company code, and a serial number. No other forms of naming are permissible.

3.1.2. Need for names to be meaningful

Names in this TPKI **MUST** be meaningful. It **SHALL** be possible to map from a name within a certificate to a legal entity, and thus who is responsible for a certificate and its corresponding private key.

3.1.3. Anonymity or pseudonymity of subscribers

Subscribers to this PKI **SHALL NOT** be anonymous.

3.1.4. Rules for interpreting various name forms

3.1.4.1. Standard certificates

The primary identifier of a certificate is the combination of company code and key ID. That alone **MUST** be sufficient to identify a certificate, and therefore public key, for verifying a ticket barcode.

3.1.4.2. STAR Certificates

STAR Certificates are identified by their inclusion in a ticket barcode. Their serial number exists only to effectuate the checking of the revocation status of a STAR certificate.

3.1.5. Uniqueness of names

Names within this PKI **MUST** be unique. No certificate is permitted to be issued with an identical subject name, unless it is issued to the same legal entity for the same subject public key information as an extant certificate.

3.1.6. Recognition, authentication, and role of trademarks

No stipulation.

3.2. Initial identity validation

3.2.1. Method to prove possession of private key

TODO: some way to verify that the correct key is installed in the ticketing system requesting issuance. This is to avoid fuckups again similar to Salzburg and NS.

3.2.2. Authentication of organization identity

The CA **MUST**, in its CPS, detail how it verifies the particulars of an applicant organisation.

3.2.3. Authentication of individual identity

The CA **MUST**, in its CPS, detail how it verifies the identity of an individual applying on behalf of an organisation

3.2.4. Non-verified subscriber information

No stipulation.

3.2.5. Validation of authority

No stipulation.

3.2.6. Criteria for interoperation

The CA **MUST**, in its CPS, detail how it verifies that an individual is authorised to apply on behalf of an organisation.

3.3. Identification and authentication for re-key requests

3.3.1. Identification and authentication for routine re-key

All requests for a certificate issuance **MUST** be treated independently, and assessed on their own merits.

3.3.2. Identification and authentication for re-key after revocation

All requests for a certificate issuance **MUST** be treated independently, and assessed on their own merits.

3.4. Identification and authentication for revocation request

Requests to revoke a certificate **MUST** be verified to the same level as was used to verify the application for issuance.

4. Certificate Life-Cycle Operational Requirements

4.1. Certificate Application

4.1.1. Who can submit a certificate application

Any entity wishing to issue ticketing barcodes **SHOULD** obtain a certificate from a CA suitable for the environment in which their barcodes will be verified, e.g. the UIC CA for international railway ticketing.

The application procedure **MUST** be described in the CPS for each CA.

4.1.2. Enrollment process and responsibilities

The applicant **MUST** generate a key pair themselves and communicate such public key to the RA along with their application particulars. No party is permitted to generate the key pair on behalf of the applicant. The RA verifies the application, and communicates the request to the CA for issuance, via a secured channel.

The exact details of the application particulars **MUST** be described in the CPS for each CA.

4.2. Certificate application processing

CAs **SHOULD** make use of extant standards for processing certificate requests. Each CA **MUST** define in its CPS, the certificate request and response standards that it employs.

4.2.1. Performing identification and authentication functions

It is the responsibility of the RA to verify the providence of applications, and that the application is allowable per this TPKI and its CPS. The legal identity of the applicant organisation **MUST** be established, as certificates in this TPKI are bound to legal entities.

4.2.2. Approval or rejection of certificate applications

The details of how certificate applications are approved **MUST** be described in the CA's CPS

4.2.3. Time to process certificate applications

No stipulation.

4.3. Certificate issuance

4.3.1. CA actions during certificate issuance

When a CA deems an application acceptable, it **MUST** issue the corresponding certificate and publish it its corresponding repository.

4.3.2. Notification to subscriber by the CA of issuance of certificate

The CA **MUST** notify the applicant of certificate issuance, and **SHOULD** attach a copy of the certificate to this notification.

4.4. Certificate acceptance

4.4.1. Conduct constituting certificate acceptance

No stipulation.

4.4.2. Publication of the certificate by the CA

The CA **MUST** publish the certificate it its corresponding repository, unless it is a STAR certificate.

4.4.3. Notification of certificate issuance by the CA to other entities

No stipulation.

4.5. Key pair and certificate usage

4.5.1. Subscriber private key and certificate usage

The subscriber **MUST** take all reasonable steps to ensure its private key is secured and is not mis-used.

A CA **MAY**, in its CPS, place further restrictions on the handling of subscriber private keys.

4.5.2. Relying party public key and certificate usage

A relying party **MUST** make reasonable efforts to check the validity and revocation status of a certificate before accepting it for ticketing purposes, i.e. with CRLs or OCSP.

4.6. Certificate renewal

4.6.1. Circumstance for certificate renewal

4.6.1.1. Standard Certificates

Certificates in this TPKI **MUST NOT** be renewed. Once a key ID (see [Section 3.1.1.1](#)) is attached to a public key, that public key is considered 'spent', and a certificate with that public key **MUST NOT** be further renewed beyond its original lifetime. This stipulation does not apply to STAR certificates, as they do not include a key ID.

4.6.1.2. STAR Certificates

A STAR certificate may be renewed up to the cryptographic lifetime of its public key.

A renewed STAR certificate **MUST** be identical to the old certificate, except for a new serial number, and different validity dates. The validity dates **SHOULD** overlap.

4.6.2. Who may request renewal

4.6.2.1. Standard Certificates

Not applicable.

4.6.2.2. STAR Certificates

Only the certificate holder or the issuing CA may initiate renewal. The certificate holder **MAY** request an early renewal, if it, as an example, expects to be unavailable to support the renewal process during the normal expiration period. An issuing CA **MAY** initiate the renewal process based on the certificate expiration date.

4.6.3. Processing certificate renewal requests

4.6.3.1. Standard Certificates

Not applicable.

4.6.3.2. STAR Certificates

The CA **MUST** verify that the certificate has not been revoked before renewing it. It **MUST** issue the renewed certificate to the same subject public key.

4.6.4. Notification of new certificate issuance to subscriber

No additional stipulations beyond [Section 4.3.2](#).

4.6.5. Conduct constituting acceptance of a renewal certificate

No additional stipulations beyond [Section 4.4.1](#).

4.6.6. Publication of the renewal certificate by the CA

No additional stipulations beyond [Section 4.4.2](#).

4.6.7. Notification of certificate issuance by the CA to other entities

No additional stipulations beyond [Section 4.4.3](#).

4.7. Certificate re-key**4.7.1. Circumstance for certificate re-key**

Certificates in this TPKI **MUST NOT** be re-keyed.

4.7.2. Who may request certification of a new public key

Not applicable.

4.7.3. Processing certificate re-keying requests

Not applicable.

4.7.4. Notification of new certificate issuance to subscriber

Not applicable.

4.7.5. Conduct constituting acceptance of a re-keyed certificate

Not applicable.

4.7.6. Publication of the re-keyed certificate by the CA

Not applicable.

4.7.7. Notification of certificate issuance by the CA to other entities

Not applicable.

4.8. Certificate modification**4.8.1. Circumstance for certificate modification**

Certificates in this TPKI **MUST NOT** be modified.

4.8.2. Who may request certificate modification

Not applicable.

4.8.3. Processing certificate modification requests

Not applicable.

4.8.4. Notification of new certificate issuance to subscriber

Not applicable.

4.8.5. Conduct constituting acceptance of modified certificate

Not applicable.

4.8.6. Publication of the modified certificate by the CA

Not applicable.

4.8.7. Notification of certificate issuance by the CA to other entities

Not applicable.

4.9. Certificate revocation and suspension

4.9.1. Circumstances for revocation

4.9.2. Who can request revocation

4.9.3. Procedure for revocation request

4.9.4. Revocation request grace period

4.9.5. Time within which CA must process the revocation request

4.9.6. Revocation checking requirement for relying parties

4.9.7. CRL issuance frequency

4.9.8. Maximum latency for CRLs

4.9.9. On-line revocation/status checking availability

4.9.10. On-line revocation checking requirements

4.9.11. Other forms of revocation advertisements available

4.9.12. Special requirements re key compromise

4.9.13. Circumstances for suspension

4.9.14. Who can request suspension

4.9.15. Procedure for suspension request

4.9.16. Limits on suspension period

4.10. Certificate status services

4.10.1. Operational characteristics

4.10.2. Service availability

4.10.3. Optional features

4.11. End of subscription

If a subscriber decides it no longer wishes to utilise the services of a CA, or a CA decides it no longer wishes to provide services to that subscriber, the CA **MUST** revoke all unexpired certificates issued to that subscriber.

4.12. Key escrow and recovery

4.12.1. Key escrow and recovery policy and practices

4.12.2. Session key encapsulation and recovery policy and practices

5. Facility, management, and operational controls

5.1. Physical controls

5.1.1. Site location and construction

5.1.2. Physical access

5.1.3. Power and air conditioning

5.1.4. Water exposures

5.1.5. Fire prevention and protection

5.1.6. Media storage

5.1.7. Waste disposal

5.1.8. Off-site backup

5.2. Procedural controls

5.2.1. Trusted roles

5.2.2. Number of persons required per task

5.2.3. Identification and authentication for each role

5.2.4. Roles requiring separation of duties

5.3. Personnel controls

5.3.1. Qualifications, experience, and clearance requirements

5.3.2. Background check procedures

5.3.3. Training requirements

5.3.4. Retraining frequency and requirements

5.3.5. Job rotation frequency and sequence

5.3.6. Sanctions for unauthorized actions

5.3.7. Independent contractor requirements

5.3.8. Documentation supplied to personnel-

5.4. Audit logging procedures

- 5.4.1. Types of events recorded**
- 5.4.2. Frequency of processing log**
- 5.4.3. Retention period for audit log**
- 5.4.4. Protection of audit log**
- 5.4.5. Audit log backup procedures**
- 5.4.6. Audit collection system (internal vs. external)**
- 5.4.7. Notification to event-causing subject**
- 5.4.8. Vulnerability assessments**

5.5. Records archival

- 5.5.1. Types of records archived**
- 5.5.2. Retention period for archive**
- 5.5.3. Protection of archive**
- 5.5.4. Archive backup procedures**
- 5.5.5. Requirements for time-stamping of records**
- 5.5.6. Archive collection system (internal or external)**
- 5.5.7. Procedures to obtain and verify archive information**

5.6. Key changeover

5.7. Compromise and disaster recovery

- 5.7.1. Incident and compromise handling procedures**
- 5.7.2. Computing resources, software, and/or data are corrupted**
- 5.7.3. Entity private key compromise procedures**
- 5.7.4. Business continuity capabilities after a disaster**

5.8. CA or RA termination

Each root CA in this TPKI stands independently and there exists no higher authority to terminate their right to be a CA, except that of distrust by relying parties.

This CP makes no stipulation about the procedures for a CA terminating its relationship with an RA.

6. Technical Security Controls

6.1. Key pair generation and installation

- 6.1.1. Key pair generation**
- 6.1.2. Private key delivery to subscriber**
- 6.1.3. Public key delivery to certificate issuer**
- 6.1.4. CA public key delivery to relying parties**
- 6.1.5. Key sizes**
- 6.1.6. Public key parameters generation and quality checking**
- 6.1.7. Key usage purposes (as per X.509 v3 key usage field)**

6.2. Private Key Protection and Cryptographic Module Engineering Controls

- 6.2.1. Cryptographic module standards and controls**
- 6.2.2. Private key (n out of m) multi-person control**
- 6.2.3. Private key escrow**
- 6.2.4. Private key backup**
- 6.2.5. Private key archival**
- 6.2.6. Private key transfer into or from a cryptographic module**
- 6.2.7. Private key storage on cryptographic module**
- 6.2.8. Method of activating private key**
- 6.2.9. Method of deactivating private key**
- 6.2.10. Method of destroying private key**
- 6.2.11. Cryptographic Module Rating**

6.3. Other aspects of key pair management

- 6.3.1. Public key archival**
- 6.3.2. Certificate operational periods and key pair usage periods**

6.4. Activation data

- 6.4.1. Activation data generation and installation**
- 6.4.2. Activation data protection**
- 6.4.3. Other aspects of activation data**

6.5. Computer security controls

6.5.1. Specific computer security technical requirements

6.5.2. Computer security rating

6.6. Life cycle technical controls

6.6.1. System development controls

6.6.2. Security management controls

6.6.3. Life cycle security controls

6.7. Network security controls

6.8. Time-stamping

7. Certificate, CRL, and OCSP Profiles

7.1. Certificate profile

7.1.1. Version number(s)

For standard certificates they **MUST** be version 3 certificates as per [RFC5280]. For STAR Certificates they **MUST** follow the format defined in [Appendix B](#).

7.1.2. Certificate extensions

7.1.2.1. Root CA

Root CA certificates in this PKI **MUST** include the following extensions:

- basicConstraints; **MUST** be critical; **MUST** have cA set to true, and **MUST NOT** not have a path length constraint.
- keyUsage; **MUST** be critical; **MUST** assert only keyCertSign and cRLSign.
- extKeyUsage; **MUST** be critical; **MUST** assert only the Trust Anchor EKU, see [Appendix A. 2.1](#).
- subjectKeyIdentifier; **MUST NOT** be critical.
- authorityKeyIdentifier; **MUST NOT** be critical; **MUST** include only keyIdentifier with a value identical to subjectKeyIdentifier.
- certificatePolicies; see [Section 7.1.6](#).

Root CA certificates **MAY** include other extensions, per the CA's CPS.

Certificates which do not assert the Trust Anchor EKU **MUST NOT** be accepted by relying parties as a root of trust.

7.1.3. Algorithm object identifiers

For the following cryptographic algorithms, the following OIDs **MUST** be used:

- NIST ECC P-256: 1.2.840.10045.3.1.7
- NIST ECC P-384: 1.3.132.0.34
- NIST ECC P-521: 1.3.132.0.35
- TODO: more

Elliptic curve subject public keys **MUST** use a named curve OID, and **MUST NOT** use explicit curve parameters.

A CA **MAY**, in its CPS, define the OIDs it uses for other cryptographic algorithms.

7.1.4. Name forms

[Section 3.1.1.1](#) defines the required and optional name attributes in this PKI.

For each certificate the value of the issuer field **MUST** be byte-for-byte identical to the value of the subject field of the issuing CA certificate.

When encoding a name, CAs **MUST** encode them as such:

- A name **MUST** be an RDNSequence.
- Each RelativeDistinguishedName **MUST** contain exactly one AttributeTypeAndValue.
- RelativeDistinguishedNames **MUST** be placed in the RDNSequence in the following order:
 1. ISO 3166 Country Code
 2. State or province name
 3. Organisation name
 4. Company code
 5. Common name
 6. Any CA specific attributes
 7. Key ID
- Each Name **MUST NOT** contain more than one instance of a given AttributeTypeAndValue.

7.1.5. Name constraints

Name constraints **MUST NOT** be used in this PKI.

7.1.6. Certificate policy object identifier

For standard certificates, the certificate policy extension **MUST** be included, asserting this document's OID, as defined in [Section 1.2](#). This extension **MUST** be marked critical.

7.1.7. Usage of Policy Constraints extension

This extension **MUST NOT** be present.

7.1.8. Policy qualifiers syntax and semantics

The certificate policy extension **MUST** include the CA's CPS in a CPSuri qualifier.

A CA **MAY** include a textual notice in its policy qualifiers. If it does so it **MUST** use the explicitText form. A relying party encountering such a notice **MUST** display it during ticket control.

7.1.9. Processing semantics for the critical Certificate Policies extension

Relying parties **MUST** reject certificates asserting a CP they do not deem acceptable.

7.2. CRL Profile

7.2.1. Version number(s)

CAs **MUST** issue version 2 CRLs as per [RFC5280]. CRLs **MUST NOT** include Indirect or Delta CRLs. The scope of each CRL **MUST** be all certificates issued by a CA.

The contents of the CRL is a list of all non-expired certificates that have been revoked by the CA. Where two or more CRLs are issued by the same CA, the CRL with the highest value of the "CRL Number" field supersedes all other CRLs issued by this CA.

7.2.2. CRL and CRL entry extensions

A CRL **MUST** include the CRL Number and the Authority Key Identifier extensions. A CRL **MUST NOT** include any other extension.

A CRL entry **MUST** include a Reason extension.

A CRL entry **MAY** include a Revocation Notice extension (see [Appendix A.3.1](#)). If present, relying parties **MUST** display this during ticket inspection.

A CRL entry **MUST NOT** include any other extensions.

7.3. OCSP Profile

7.3.1. Version number(s)

A CA **MUST** provide a version 1 OCSP service as per [RFC6960].

CAs **MUST** generate a separate OCSP responder certificate, they **MUST NOT** use the CA certificate to sign OCSP responses.

7.3.2. OCSP extensions

CAs **MUST** support the OCSP Nonce extension.

CAs **MAY** support other responseExtensions.

The singleExtensions of an OCSP response **MUST NOT** contain the reasonCode CRL entry extension.

The singleExtensions of an OCSP response **MAY** contain the Revocation Notice extension. It **MUST** be present if also present in the CRL, and vice versa. Relying parties **MUST** process it the same as if it was in the CRL.

The singleExtensions of an OCSP response **MUST NOT** contain any other extension.

8. Compliance, Audit, and Other Assessments

8.1. Frequency or circumstances of assessment

8.2. Identity/qualifications of assessor

8.3. Assessor's relationship to assessed entity

8.4. Topics covered by assessment

8.5. Actions taken as a result of deficiency

8.6. Communication of result

9. Other Business and Legal Matters

9.1. Fees

9.1.1. Certificate issuance or renewal fees

No stipulation.

9.1.2. Certificate access fees

No fees may be levied by participants in this TPKI for access to certificates.

9.1.3. Revocation or status information access fees

No fees may be levied by participants in this TPKI for access to revocation information.

9.1.4. Fees for other services

No stipulation.

9.1.5. Refund policy

No stipulation.

9.2. Financial responsibility

9.2.1. Insurance coverage

No stipulation.

9.2.2. Other assets

No stipulation.

9.2.3. Insurance or warranty coverage for end-entities

No stipulation.

9.3. Confidentiality of business information**9.3.1. Scope of confidential information**

No stipulation.

9.3.2. Information not within the scope of confidential information

No stipulation.

9.3.3. Responsibility to protect confidential information

No stipulation.

9.4. Privacy of personal information**9.4.1. Privacy plan**

Participants in this TPKI **MUST** have an appropriate plan to preserve the privacy of personal information insofar as it is processed within the TPKI. This plan **MUST** be compliant with the European Union's General Data Protection Regulations.

9.4.2. Information treated as private

At a minimum, the following information **MUST** be treated as private:

- A person's name
- A person's email
- A person's date of birth
- A person's home address
- A person's phone number

That information is to be treated as private does not preclude its disclosure if appropriate circumstances necessitate it.

9.4.3. Information not deemed private

At a minimum, the following information **MUST NOT** be treated as private:

- Names of organisations
- Identifiers (e.g. company registration numbers) of organisations
- RICS company codes
- ERA organisation codes
- Email addresses of organisations
- Addresses of organisations

9.4.4. Responsibility to protect private information

All parties in this TPKI **MUST** work to protect private information, in accordance with the European Union's General Data Protection Regulations and any applicable local regulations.

9.4.5. Notice and consent to use private information

No stipulation.

9.4.6. Disclosure pursuant to judicial or administrative process

No stipulation.

9.4.7. Other information disclosure circumstances

No stipulation.

9.5. Intellectual property rights

No stipulation.

9.6. Representations and warranties**9.6.1. CA representations and warranties**

No stipulation.

9.6.2. RA representations and warranties

No stipulation.

9.6.3. Subscriber representations and warranties

No stipulation.

9.6.4. Relying party representations and warranties

No stipulation.

9.6.5. Representations and warranties of other participants

No stipulation.

9.7. Disclaimers of warranties

No stipulation.

9.8. Limitations of liability

No stipulation.

9.9. Indemnities

No stipulation.

9.10. Term and termination**9.10.1. Term**

This CP comes into effect from XX/XX/XXXX.

This CP remains in force unless otherwise amended or rescinded.

9.10.2. Termination

This CP may be rescinded at the sole discretion of the UIC TSG. The effective date of this **MUST** be at least 6 months into the future from the date of publication.

9.10.3. Effect of termination and survival

No stipulation.

9.11. Individual notices and communications with participants

No stipulation.

9.12. Amendments

9.12.1. Procedure for amendment

This CP may be amended at the sole discretion of the UIC TSG.

9.12.2. Notification mechanism and period

Notification of such amendment, and the new version of this CP **MUST** be posted on the UIC's website.

Subsequent editions of this CP **MUST** include the date at which they are to come into effect. Such a date **MUST** be at least 3 months into the future from the date of publication.

The notification of an amended CP **SHOULD** include a changelog of what modifications have been made to the CP.

9.12.3. Circumstances under which OID must be changed

If the UIC TSG judges that changes to the CP do not materially change the acceptability of certificates for ticketing purposes, there will be no change to the CP OID. If the UIC TSG judges that changes to the CP do materially change the acceptability of certificates for ticketing purposes, then there **MUST** be a new CP OID.

9.13. Dispute resolution provisions

No stipulation

9.14. Governing law

Unless otherwise agreed, this CP, CPSeS, and any additional agreements, are to be governed by the laws of France.

9.15. Compliance with applicable law

Parties **SHALL** issue Certificates and operate within this TPKI in accordance with all law applicable to its business in every jurisdiction in which they operate.

9.16. Miscellaneous provisions

9.16.1. Entire agreement

No stipulation

9.16.2. Assignment

No stipulation

9.16.3. Severability

In the event of a conflict between this CP and a law, regulation or government order of any jurisdiction in which a party operates, such party **MAY** modify any conflicting requirement to the minimum extent necessary to make the requirement valid and legal in said jurisdiction. This applies only to operations subject to such requirement.

In cases of a CA it **SHALL** immediately, prior to issuing a certificate under the modified requirement, include in Section 9.16.3 of its CPS a reference to the regulation requiring a deviation from this CP, and how such a modification is implemented by the CA. The CA **MUST** also inform, prior to issuance, the responsible contact person for this CP, such that an amendment to the CP may be considered.

Any modification to these requirements **MUST** be discontinued as soon as the relevant regulation ceases to have effect, or this CP is modified in such a way to make it possible to comply with both simultaneously.

9.16.4. Enforcement (attorneys' fees and waiver of rights)

No stipulation

9.16.5. Force Majeure

No stipulation

9.17. Other provisions

No stipulation

10. References

10.1. Normative References

[BCP14] Best Current Practice 14, <<https://www.rfc-editor.org/info/bcp14>>. At the time of writing, this BCP comprises the following:

Bradner, S., "Key words for use in RFCs to Indicate Requirement Levels", BCP 14, RFC 2119, DOI 10.17487/RFC2119, March 1997, <<https://www.rfc-editor.org/info/rfc2119>>.

Leiba, B., "Ambiguity of Uppercase vs Lowercase in RFC 2119 Key Words", BCP 14, RFC 8174, DOI 10.17487/RFC8174, May 2017, <<https://www.rfc-editor.org/info/rfc8174>>.

- [ISO3166-1]** International Organization for Standardization, "Codes for the representation of names of countries and their subdivisions - Part 1: Country code", ISO 3166-1:2020, <<https://www.iso.org/standard/72482.html>>.
- [ISO3166-2]** International Organization for Standardization, "Codes for the representation of names of countries and their subdivisions - Part 2: Country subdivision code", ISO 3166-2:2020, <<https://www.iso.org/standard/72483.html>>.
- [RFC2797]** Myers, M., Liu, X., Schaad, J., and J. Weinstein, "Certificate Management Messages over CMS", RFC 2797, DOI 10.17487/RFC2797, April 2000, <<https://www.rfc-editor.org/info/rfc2797>>.
- [RFC3647]** Chokhani, S., Ford, W., Sabett, R., Merrill, C., and S. Wu, "Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework", RFC 3647, DOI 10.17487/RFC3647, November 2003, <<https://www.rfc-editor.org/info/rfc3647>>.
- [RFC5280]** Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R., and W. Polk, "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile", RFC 5280, DOI 10.17487/RFC5280, May 2008, <<https://www.rfc-editor.org/info/rfc5280>>.
- [RFC6960]** Santesson, S., Myers, M., Ankney, R., Malpani, A., Galperin, S., and C. Adams, "X.509 Internet Public Key Infrastructure Online Certificate Status Protocol - OCSP", RFC 6960, DOI 10.17487/RFC6960, June 2013, <<https://www.rfc-editor.org/info/rfc6960>>.
- [RFC9110]** Fielding, R., Ed., Nottingham, M., Ed., and J. Reschke, Ed., "HTTP Semantics", STD 97, RFC 9110, DOI 10.17487/RFC9110, June 2022, <<https://www.rfc-editor.org/info/rfc9110>>.

10.2. Informative References

Appendix A. ASN.1 Definitions

This section details the additional ASN.1 elements defined in addition to those of [RFC5280] that are required for the operation of a TPKI.

OIDs defined for these extensions are under the following arc:

```
id-as207960-uic OBJECT IDENTIFIER ::= { 1 3 6 1 4 1 56292 1 3 }
```

A.1. Name Attributes

This document defines two new name attributes for identifying companies and their signing keys in their certificates.

Name Attributes are defined under the following arc:

```
id-at OBJECT IDENTIFIER ::= { id-as207960-uic 2 }
```

A.1.1. Company Code Name Attribute

This attribute is defined by the following OID and ASN.1:

```
id-at-companyCode OBJECT IDENTIFIER ::= { id-at 1 }
X520CompanyCode ::= CompanyCode

CompanyCode ::= CHOICE {
    codeNum INTEGER (1..32000),
    codeIA5 IA5String
}
```

The codeNum variant **MUST** be used in case the organisation has a RICS code, or is otherwise identified by a numeric ID. The numbers 0 through 9999 **MUST** only be used to specify RICS codes, other coding schemes **MUST** be placed above 9999.

The codeIA5 variant **MAY** be used in case the organisation has an ERA company code, but no RICS code, or is otherwise only identified by an alphanumeric code.

A.1.2. Key ID Attribute

This attribute is used in the ticket barcode to identify the end-entity certificate used to verify the ticket. The combination of the company code and key ID uniquely identifies the key pair used to sign the ticket.

The attribute is defined by the following OID and ASN.1:

```
it-at-keyId OBJECT IDENTIFIER ::= { id-at 2 }
X520KeyId ::= Choice {
    number INTEGER (0..99999), -- For DOSIPAS envelopes,
    ia5 IA5String (SIZE (5)) -- For #UT envelopes
}
```

In the case of a purely numeric key ID, the number variant **SHALL** be used, otherwise the ia5 variant **SHALL** be used.

A.2. Extended Key Usages

Extended Key Usages are defined under the following arc:

```
id-eku OBJECT IDENTIFIER ::= { id-as207960-uic 1 }
```

A.2.1. Trust Anchor EKU

This EKU is defined by the following OID:

```
id-eku-trustAnchor OBJECT IDENTIFIER ::= { id-eku 1 }
```

This EKU marks that a certificate is intended to be used as a trust anchor.

A.3. Certificate Extensions

Certificate Extensions are defined under the following arc:

```
id-ext OBJECT IDENTIFIER ::= { id-as207960-uic 3 }
```

A.3.1. Revocation Notice Extension

This extension defines a notice to be displayed to inspection staff upon encountering a revoked certificate.

The extension is defined by the following OID and ASN.1:

```
it-ext-revocationNotice OBJECT IDENTIFIER ::= { id-ext 2 }  
RevocationNotice ::= UTF8String
```

Appendix B. STAR Certificate Format

Author's Address

Q Misell (EDITOR)

Max-Planck Institut für Informatik
Campus E1.4
66125 Saarbrücken
Germany
Email: qmisell@mpi-inf.mpg.de
URI: <https://magicalcodewit.ch>